# Smart Pet Care App - Privacy Policy

Version 1.3. Effective 6 November 2026. Published at https://smart-pet-care.duckdns.org/privacy

## 1. Who is responsible, and what this covers

Smart Pet Care App is a collaborative student project consisting of a mobile client, a backend API and supporting services. The Smart Pet Care App project team ("we", "us", "our") is the controller for the personal data described here. The project, its components and its contributors are documented at https://github.com/Gmust/smart-pet-care-app, which is the route for reaching us and for making any of the requests in section 11.

This policy covers personal data processed through the App and the API at https://smart-pet-care.duckdns.org. It is written against the EU General Data Protection Regulation (GDPR) and uses its vocabulary. The **Terms and Conditions** at https://smart-pet-care.duckdns.org/terms govern your use of the Service itself.

## 2. The short version

- You give us an email address to have an account, and whatever you choose to record about your pets.
- We use it to run the Service for you: store your records, fire your reminders, answer your questions. Nothing else.
- We do not sell personal data, we do not share it for advertising, and we run no advertising or analytics trackers.
- The AI features send pet records and your chat messages to the project's own AI service. Keep sensitive information about people out of those fields.
- You can see, correct, export and delete your data, and you can delete your whole account from the App.

## 3. What we process

### 3.1 Account data

Your email address; a password hash if you signed up with a password (hashed with bcrypt - we never hold the password itself); optionally a display name, a phone number and a profile picture; whether and when you accepted the Terms; whether and when you confirmed your email; and the dates your account was created and last changed.

If you sign up with a password we send a confirmation code to your email and store it, hashed, until it is used or expires 15 minutes later. While an address is not yet confirmed, the bcrypt hash of the password that sign-up chose is kept with the code rather than on the account, and is applied to the account when the code is used. This is what stops a second sign-up for an address someone else is in the middle of confirming from setting the password on it.

If you ask to reset a forgotten password we email you a link and store the token it carries, hashed, until the link is used or expires 30 minutes later. We do not record the addresses that were entered, and the reply we send back is the same whether or not an address has an account - though we do not claim that someone watching closely could not tell the difference.

### 3.2 Signing in with Google

If you choose Google sign-in, Google tells us the identifier of your Google account, your email address and, if you have them, your name and profile picture. We store the link between your Smart Pet Care account and that Google account so you can sign in again. We never receive your Google password, and we ask Google for nothing beyond basic profile and email.

### 3.3 Pet profiles

For each pet: name, species, breed, date of birth, sex, weight, and the free-text notes you keep about behaviour, allergies and chronic conditions. Optionally a photo.

### 3.4 Pet care and health records

Everything you record over time against a pet: feeding logs, weight history, activity and sleep logs, journal entries (including symptoms and a severity), conditions, medications and their schedules, health records such as vaccinations and vet visits, free-text notes, reminders and the history of when each one was completed, nutrition goals, and the wellness scores and feeding analyses generated from all of it.

### 3.5 Files you upload

Photos and documents you attach to a pet, along with their file name, type, size and any description you add.

### 3.6 Assistant conversations

Your messages to the AI assistant, its replies, and the session they belong to. Recent messages in a session are replayed as context for the next question.

### 3.7 Devices, sessions and technical data

- A push notification token for each device you allow notifications on, with the platform (Android, iOS or web) and when it was last seen. The token identifies a device to Google's messaging service; it is not an advertising identifier.
- Session data: refresh tokens, stored as SHA-256 hashes rather than in the clear, with their expiry, whether they have been revoked, an identifier for the sign-in they belong to and the hash of the token that replaced each one. Those last two are what let us end a single session - and only that session - when a token is presented twice, which is what the theft of a token looks like. The API returns both tokens to the app in the response body; where they are then kept is the app's responsibility, and on a phone that is the platform's protected storage for the app.
- Server logs produced by handling your requests, which contain IP addresses, the requested route, timestamps, response status, user agent and a trace identifier. These are operational records used to find faults and detect abuse.

### 3.8 What we do not collect

We do not collect location data, contacts, advertising identifiers or device sensor data, we do not run third-party analytics or advertising SDKs on the backend, and we do not profile you for marketing.

## 4. A note on pet data, and on free text

Information about an animal is not personal data about a person, so a pet's health record is not "data concerning health" in the GDPR sense and the special rules for that category do not apply to it.

But the same records are linked to you, and free-text fields do not police what goes into them. A journal entry, a note or a chat message can easily end up containing information about **you** or about another person - a household detail, a sitter's phone number, your own health. Please do not put sensitive personal information about anyone into those fields. We treat whatever is there as ordinary personal data under this policy, and the AI features send those fields on as described in section 7.

## 5. Why we process it, and on what legal basis

- **To provide the Service** - keeping your account, storing and showing your pet records, calculating reminder schedules, delivering notifications, answering assistant questions. Legal basis: performance of a contract with you (Art. 6(1)(b) GDPR).
- **To verify your email address** and to let you sign in with Google. Legal basis: performance of a contract (Art. 6(1)(b)).
- **To send account and security email** - confirmation codes, password reset links, security notices, notice of changes to the Terms. Legal basis: performance of a contract (Art. 6(1)(b)).
- **To keep the Service secure and working** - authentication, authorisation checks that keep your pets visible only to you, rate limiting, abuse detection, fault diagnosis from logs, and backups so a failure does not lose your records. Legal basis: our legitimate interest in a secure and reliable service (Art. 6(1)(f)).
- **To send push notifications** to a device. Legal basis: your consent, given through your device's notification permission (Art. 6(1)(a)); withdraw it by turning notifications off, which also unregisters the device.
- **To comply with the law**, where we are obliged to. Legal basis: legal obligation (Art. 6(1)(c)).

## 6. Automated processing and no automated decisions

Wellness scores, feeding summaries and assistant replies are produced automatically from your records. They are informational suggestions about an animal's care. They produce no legal effects for you, nothing is decided about you on their basis, and they are not automated decision-making or profiling within the meaning of Art. 22 GDPR. They are also not veterinary advice - see section 3 of the Terms.

## 7. Who else receives it

We use the following processors and third parties. Each receives only what its function requires.

- **The project's AI service** - receives your assistant messages and recent conversation context, and, for the wellness and feeding features, the pet profile and aggregated care records the analysis is computed from. It is operated as part of this project.
- **Cloudinary** (image hosting) - receives pet photos you upload, and serves them back to the App.
- **Google** - as the sign-in provider when you use Google sign-in, and as the operator of Firebase Cloud Messaging, which delivers push notifications. Firebase receives your device token and the content of the notification, which includes the pet's name and the reminder's description.
- **Our email provider** - receives your email address and the content of the message in order to deliver confirmation codes and account email.
- **Amazon Web Services** - stores encrypted database backups in a restricted bucket in the us-east-1 region. These contain the production database and therefore your records.
- **Our hosting provider** - operates the virtual server the API and database run on.

We do not sell personal data, and we do not disclose it to anyone else except where we are legally required to, or where it is necessary to establish or defend a legal claim.

## 8. International transfers

Cloudinary, Google and Amazon Web Services may process data outside the European Economic Area, including in the United States. Where that happens, the transfer relies on the mechanisms those providers make available for it - the EU Standard Contractual Clauses and, where applicable, the EU-US Data Privacy Framework. You can ask us for details of the safeguards that apply to a specific provider.

## 9. How long we keep it

- **Account and pet data** - until you delete your account, or you delete the individual pet or record. Deleting an account deletes the account and the pets and records belonging to it.
- **Email confirmation codes** - 15 minutes, then they are expired and unusable. The password hash held with an unconfirmed sign-up's code expires with it.
- **Password reset tokens** - usable for 30 minutes and for one reset, then they are expired and unusable; asking for a new link also cancels the previous one. The hashed record of a spent link is kept with the account.
- **Refresh tokens** - 7 days from issue; revoked immediately when you sign out of that device or change your password. Resetting a forgotten password revokes them on every device, so each one has to sign in again. Signing out and resetting a password also stop the short-lived access token already issued to the app from being accepted, instead of letting it run its remaining minutes.
- **Push notification tokens** - until you turn notifications off, you sign out of that device, or the token goes unused for 60 days, after which it is pruned. Registering a device under a different account moves the token to that account. Resetting a forgotten password deletes them for every device, so a device somebody else had signed in on stops receiving your notifications.
- **Feeding analyses** - only the two most recent per pet are kept; older ones are discarded as new ones are produced.
- **Server logs** - kept short-term for fault diagnosis and security, and rotated out.
- **Backups** - encrypted database dumps are retained for a limited period (on the order of two weeks for the copies held on the server) and then deleted. A record you delete can survive in a backup until its retention lapses. Backups are restored only as a whole, to recover from failure or data loss; they are not browsed, and nothing is selectively restored from them.

## 10. Security

- All traffic is served over HTTPS/TLS.
- Passwords are stored as bcrypt hashes; refresh tokens, confirmation codes and password reset tokens as SHA-256 hashes. None of them can be read back.
- Access tokens are short-lived (15 minutes), so a token that does leak is of little use. They are sent with each request as a bearer token rather than stored by the API. Signing out or resetting a password stops the tokens issued before it from being accepted at all, rather than waiting for them to expire.
- A refresh token is replaced each time it is used, and one presented a second time ends the session it belongs to, on that device alone.
- We email you when your password changes, so a change you did not make does not go unnoticed.
- Every request for a pet's data is checked against the signed-in account, so one user cannot read another's records.
- The database is not reachable from the public internet; the API reaches it on a private network.
- Backups are taken regularly, verified after each dump, and monitored by the absence of a success signal rather than by failure reports.

- Administrative access to the server and the database is limited to the project's maintainers.

No service can promise perfect security. If a breach occurs that is likely to risk your rights and freedoms, we will notify the competent supervisory authority and, where required, you.

## 11. Your rights

Under the GDPR you have the right to:

- **access** the personal data we hold about you, and get a copy of it;
- **rectification** of data that is inaccurate or incomplete - most of it you can correct in the App directly;
- **erasure** of your data ("right to be forgotten"), which you can exercise yourself by deleting your account;
- **restriction** of processing in certain circumstances;
- **data portability** - a copy of the data you gave us, in a structured, machine-readable format;
- **object** to processing based on our legitimate interests;
- **withdraw consent** at any time where we rely on it, such as push notifications, without affecting processing that already happened;
- **not be subject** to decisions based solely on automated processing - see section 6, which explains why none are made here.

To exercise any of these, contact us through the project repository at https://github.com/Gmust/smart-pet-care-app. We will respond within one month. We may ask you to confirm you control the account's email address, so that we do not disclose someone's records to the wrong person.

You also have the right to **lodge a complaint** with a data protection supervisory authority, normally the one for your country of residence.

## 12. Children

The Service is not intended for children. You must be at least 16 to use it, or older where your country sets a higher age of digital consent. We do not knowingly process data about children below that age; if you believe we have, contact us and we will delete it.

## 13. Changes to this policy

We may update this policy as the project develops. The current version is always at https://smart-pet-care.duckdns.org/privacy, with its version number and effective date on the first page. For a change that materially affects how we use your data, we will give notice in the App or by email before it takes effect.

## 14. Contact

Smart Pet Care App project team, through the project repository at https://github.com/Gmust/smart-pet-care-app.